COMPTIA SECURITY+ SY0-701 | DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.1 · Secure Baselines

Mestre CyberSec · **Aula 4.1 — Secure Baselines** (4:11) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Baseline = config PADRÃO que toda máquina tem: imagem gold (CIS hardened), patch automático, MFA, EDR. Deploy automatizado: GPO, Intune, Ansible, SCCM — NUNCA manual.

💡 Highlights que a prova CompTIA cobra

- Baseline: o mínimo de config que toda máquina segue
- Deploy automatizado (GPO/Intune): nunca manual

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'baseline configuration applied to all workstations'=secure baseline

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.1 — Secure Baselines)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Linha de Base Segura (N/A)

Configuração mínima de segurança documentada e padronizada aplicada a todos os sistemas de um grupo, geralmente incluindo ajustes endurecidos, patches, MFA e EDR. Garante consistência e reduz a superfície de ataque.

⚠ ***Armadilha CompTIA:*** *Se a questão falar em 'baseline configuration applied to all workstations' ou 'standard security configuration', a resposta é secure baseline.*

• Imagem Gold de Referência (N/A)

Imagem mestra de SO/software pré-configurada conforme a linha de base segura e usada para implantar novos sistemas de forma consistente. Geralmente é endurecida com benchmarks CIS antes da clonagem.

⚠ ***Armadilha CompTIA:*** *Gold image = modelo padronizado; não confunda com backup. É a fonte para implantação automatizada.*

• Endurecimento do Sistema (N/A)

Processo de proteger um sistema reduzindo sua superfície de ataque, como desativar serviços, portas e contas não usados e aplicar configurações seguras. É parte essencial da criação de uma linha de base segura.

⚠ ***Armadilha CompTIA:*** *Hardening não é só patch; envolve remover/desabilitar o que não é necessário. CIS benchmarks fornecem guias de hardening.*

• Benchmarks CIS

Diretrizes prescritivas e baseadas em consenso do Center for Internet Security, usadas para endurecer SOs, aplicações e ambientes de nuvem. Ajudam a definir configurações de linha de base segura.

⚠ ***Armadilha CompTIA:*** *CIS = benchmark de hardening reconhecido. Se a questão citar 'hardened image' ou 'industry-standard secure configuration', pense em CIS.*

• Objeto de Diretiva de Grupo (GPO)

Recurso do Microsoft Active Directory usado para implantar e aplicar centralmente configurações de segurança, incluindo linhas de base seguras, em sistemas Windows ingressados no domínio. Automatiza configuração em escala.

⚠ ***Armadilha CompTIA:*** *GPO é para ambiente Windows/Active Directory. Se a questão pede implantação automatizada de baseline em domínio, escolha GPO.*

• Microsoft Intune

Serviço de gerenciamento de endpoints e dispositivos móveis (MDM) baseado em nuvem usado para implantar linhas de base de segurança, políticas e aplicativos em dispositivos Windows, macOS, iOS e Android. Suporta aplicação automatizada e remota de baseline.

⚠️ ***Armadilha CompTIA:*** *Intune = gerenciamento moderno em nuvem; GPO = tradicional on-premises AD. Escolha Intune para dispositivos não domínio/nuvem.*

• System Center Configuration Manager (SCCM)

Ferramenta de gerenciamento local da Microsoft, agora Microsoft Endpoint Configuration Manager, para implantar software, patches e configurações de conformidade em grandes ambientes Windows. Pode distribuir linhas de base seguras e aplicar configuração.

⚠️ ***Armadilha CompTIA:*** *SCCM/MECM = gerenciamento on-premises de grandes frotas Windows. Distinga de Intune (nuvem) e GPO (políticas de domínio).*

• Ansible (N/A)

Ferramenta de automação de código aberto usada para gerenciamento de configuração, implantação de aplicativos e orquestração. Pode aplicar linhas de base seguras em servidores e dispositivos de rede usando playbooks, geralmente sem agente via SSH.

⚠️ ***Armadilha CompTIA:*** *Ansible = automação agentless e playbooks; não é ferramenta Microsoft. Se a questão citar automação multi-plataforma/Linux, pense em Ansible.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa está implantando 500 novas estações de trabalho e a equipe de segurança precisa garantir configurações idênticas e reforçadas—incluindo alinhamento ao CIS, patching automático, agentes EDR e aplicação de MFA—em todos os dispositivos. Qual abordagem de implantação GARANTE melhor uma baseline segura consistente em toda a frota?

A) Solicitar que cada técnico configure manualmente todas as estações de trabalho usando uma checklist impressa de hardening

B) Construir uma gold image endurecida pelo CIS e implantá-la em toda a empresa via System Center Configuration Manager (SCCM)

C) Enviar estações de trabalho sem configura��ão e permitir que os usuários finais instalem as ferramentas de segurança que preferirem

D) Configurar as definições de segurança individualmente apenas após o primeiro login de cada usuário

QUESTÃO 2 · CENÁRIO DE EXAME

Após uma auditoria PCI-DSS, uma organização precisa aplicar o hardening do CIS Benchmark em 200 servidores Linux. A equipe de segurança exige uma solução automatizada, repetível, versionada e auditável. Qual abordagem ATENDE melhor a esse requisito?

A) Contratar um consultor externo para acessar manualmente cada servidor via SSH e aplicar as configurações CIS à mão

B) Usar playbooks Ansible que referenciam os CIS Benchmarks para automatizar o hardening em escala em todos os servidores

C) Publicar as configurações CIS em uma página wiki e confiar que cada administrador Linux as aplicará quando conveniente

D) Desativar todos os serviços não essenciais por meio de scripts shell ad-hoc salvos apenas em laptops individuais

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa financeira precisa aplicar complexidade de senha, políticas de bloqueio de conta e restrições de armazenamento USB em 2.000 máquinas Windows ingressadas no domínio. O arquiteto de segurança precisa de uma solução centralizada e escalável. Qual mecanismo APLICA melhor essas configurações de baseline?

A) Configurar a Local Security Policy manualmente em cada computador individualmente

B) Criar e vincular Group Policy Objects (GPOs) no Active Directory para enviar as configurações de baseline a todos os computadores do domínio

C) Enviar por e-mail um script de registro a cada usuário e pedir que eles o executem como administrador em suas próprias máquinas

D) Desativar a aplicação de políticas para evitar a geração de chamados no help desk

QUESTÃO 4 · CENÁRIO DE EXAME

Após a migração para o trabalho remoto, muitos funcionários de uma empresa usam laptops em redes domésticas, hotéis e cafeterias. O CISO exige que cada laptop receba a mesma baseline de segurança, independentemente de conectar-se ou não à LAN corporativa. Qual solução ATENDE melhor a esse requisito?

A) Exigir que cada funcionário remoto traga seu laptop à matriz anualmente para inspeção e reconfiguração

B) Utilizar o Microsoft Intune para enviar e aplicar continuamente políticas de baseline a partir da nuvem em todo dispositivo matriculado

C) Implantar apenas Group Policy local que exija uma conexão VPN permanente para aplicação

D) Distribuir um documento PDF com instruções de segurança para cada funcionário remoto

QUESTÃO 5 · CENÁRIO DE EXAME

Um engenheiro DevOps precisa garantir que 150 servidores de produção mantenham uma configuração de segurança uniforme e que qualquer drift de configuração seja corrigido automaticamente, sem intervenção manual. Qual ferramenta e metodologia ATENDEM melhor a esse requisito?

A) Acessar manualmente cada servidor via SSH semanalmente para executar comandos de endurecimento e torcer para que nada mude entre as visitas

B) Usar Ansible com playbooks idempotentes que referenciam a baseline segura endurecida pelo CIS, executados em agendamento contínuo

C) Pedir a cada administrador de sistemas que memorize e aplique pessoalmente as melhores práticas nos servidores sob sua responsabilidade

D) Confiar que os usuários finais abrirão chamados no help desk quando suspeitarem de um servidor mal configurado

QUESTÃO 6 · CENÁRIO DE EXAME

A equipe de conformidade precisa verificar se todos os 3.000 endpoints da organização continuam aderindo à baseline segura aprovada ao longo do tempo. Qual abordagem VALIDA melhor a aderência à baseline em escala?

A) Confiar que os administradores de sistemas reportarão honestamente seu status de conformidade a cada trimestre

B) Realizar inspeções visuais aleatórias de desktops durante visitas ocasionais às unidades

C) Usar ferramentas automatizadas de varredura de conformidade que comparam o estado real do endpoint com a baseline da gold image

D) Pular a verificação porque a gold image original já foi validada antes da implantação

QUESTÃO 7 · CENÁRIO DE EXAME

Uma indústria sofreu um incidente de ransomware que explorou endpoints sem EDR e com patches desatualizados. O CIO deseja garantir que, daqui em diante, todo endpoint seja entregue com EDR, patching automático, MFA e hardening CIS aplicados de forma consistente. Qual controle MELHOR previne a recorrência?

A) Enviar lembretes trimestrais por e-mail aos usuários finais para que instalem atualizações quando for conveniente

B) Construir uma baseline segura que reúna EDR obrigatório, patching automático, MFA e hardening CIS, e implantá-la via Intune e SCCM

C) Desativar ferramentas de segurança durante janelas de manutenção para reduzir a sobrecarga do sistema

D) Permitir que cada departamento selecione independentemente seu próprio stack de segurança conforme preferência local

QUESTÃO 8 · CENÁRIO DE EXAME

Um hospital precisa cumprir a HIPAA e exige que cada estação de trabalho que manipula PHI siga uma configuração consistente e reforçada. Qual abordagem ESTABELECE melhor uma baseline segura para esses endpoints?

A) Implementar uma gold image endurecida pelo CIS com EDR, MFA e patching automático, e implantá-la por meio de ferramentas de gerenciamento corporativo como SCCM ou Intune

B) Confiar exclusivamente em um produto antivírus de nível consumidor para proteger todas as estações com PHI

C) Permitir que a equipe clínica utilize seus smartphones e laptops pessoais sem nenhum padrão de configuração

D) Pular o endurecimento para simplificar as operações de TI e reduzir chamados no help desk

QUESTÃO 9 · CENÁRIO DE EXAME

Uma organização centrada em Windows deseja aproveitar as próprias configurações de baseline de segurança recomendadas pela Microsoft em toda a sua frota de servidores. Qual abordagem USA melhor as ferramentas da Microsoft para implantar essas baselines em escala?

A) Configurar manualmente cada servidor copiando configurações a partir de capturas de tela publicadas no site da Microsoft

B) Importar as Microsoft Security Baselines como modelos ADMX, implantá-las via Group Policy e aplicá-las por meio do SCCM

C) Ignorar as recomendações da Microsoft e inventar baselines de segurança personalizadas sem documentação

D) Desativar completamente a aplicação de baselines porque os padrões do Windows já são considerados suficientes

QUESTÃO 10 · CENÁRIO DE EXAME

Foi detectado drift de configuração em vários servidores de produção: softwares não autorizados foram instalados, regras de firewall foram modificadas e o agente EDR foi desativado. Qual solução RESTAURA melhor a baseline segura E previne recorrência?

A) Ignorar o drift contanto que os serviços afetados permaneçam em execução e acessíveis

B) Reinstalar o sistema operacional do zero em cada servidor afetado semanalmente

C) Usar ferramentas de gerenciamento de configuração como Ansible ou SCCM para detectar continuamente o drift e remediar automaticamente os endpoints para a baseline segura

D) Desativar o sistema de gerenciamento de configuração para que ele não interrompa os serviços de produção

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Construir uma gold image endurecida pelo CIS e implantá-la em toda a empresa via System Center Configuration Manager (SCCM)

Uma gold image é um modelo mestre pré-endurecido e pré-configurado, capturado uma única vez e clonado para cada endpoint. Combinada com uma ferramenta de implantação empresarial como SCCM, Intune ou Ansible, ela garante que cada estação de trabalho inicie com exatamente a mesma baseline segura (hardening CIS, EDR, políticas de patch, MFA). Abordagens manuais (A, D) são inconsistentes, lentas, propensas a erros e não escaláveis. Permitir que os usuários escolham suas próprias ferramentas (C destrutiva) destrói qualquer baseline.

Questão 2: Alternativa B — Usar playbooks Ansible que referenciam os CIS Benchmarks para automatizar o hardening em escala em todos os servidores

O Ansible é uma ferramenta de gerenciamento de configuração agentless e idempotente. Os playbooks podem codificar os CIS Benchmarks uma única vez e aplicá-los consistentemente aos 200 servidores, com logs de auditoria completos e controle de versão. Consultoria manual (A) é cara, lenta e não repetível. Uma wiki sem aplicação (C) garante drift. Scripts ad-hoc (D) não são auditáveis nem versionados e reintroduzem o drift imediatamente.

Questão 3: Alternativa B — Criar e vincular Group Policy Objects (GPOs) no Active Directory para enviar as configurações de baseline a todos os computadores do domínio

Os Group Policy Objects (GPOs) são o mecanismo nativo e escalável no Active Directory para distribuir uma baseline segura a todos os computadores ingressados no domínio. Eles são gerenciados de forma central, reaplicados automaticamente e oferecem relatórios via GPResult e logs de eventos. A Local Security Policy (A) é por máquina e não escala. Pedir aos usuários que executem scripts de registro (C) é pouco confiável e um risco de segurança. Desativar a aplicação (D) viola completamente a baseline.

Questão 4: Alternativa B — Utilizar o Microsoft Intune para enviar e aplicar continuamente políticas de baseline a partir da nuvem em todo dispositivo matriculado

O Microsoft Intune é uma plataforma de Mobile Device Management (MDM) e Mobile Application Management (MAM) baseada em nuvem que entrega perfis de configuração de baseline, regras de conformidade e acesso condicional a partir da nuvem. Ele funciona para dispositivos remotos, móveis e que nunca usam VPN. Visitas anuais (A) deixam os endpoints desprotegidos por 364 dias. Apenas GPO/VPN (C) falha quando os dispositivos estão offline. Um PDF (D) não fornece nenhuma aplicação real.

Questão 5: Alternativa B — Usar Ansible com playbooks idempotentes que referenciam a baseline segura endurecida pelo CIS, executados em agendamento contínuo

Os playbooks Ansible são idempotentes—executá-los repetidamente faz o sistema convergir para o estado desejado sem efeitos colaterais. Combinados com uma execução agendada (ou um agente em modo pull), o Ansible identifica e corrige automaticamente o drift em relação à baseline endurecida pelo CIS nos 150 servidores. SSH manual (A) não escala e é reativo. Depender de memória (C) ou dos usuários finais (D) não oferece nenhuma aplicação real da baseline.

Questão 6: Alternativa C — Usar ferramentas automatizadas de varredura de conformidade que comparam o estado real do endpoint com a baseline da gold image

Scanners automatizados de conformidade (por exemplo, Nessus, Microsoft Defender for Endpoint, CIS-CAT, relatórios de conformidade do Intune) comparam continuamente os endpoints em execução com a gold image aprovada ou perfil CIS e produzem relatórios auditáveis. Auto-reportes (A) e inspeções visuais (B) não escalam e são pouco confiáveis. Pular a verificação (D) garante que o drift passe despercebido, anulando o propósito de se ter uma baseline.

Questão 7: Alternativa B — Construir uma baseline segura que reúna EDR obrigatório, patching automático, MFA e hardening CIS, e implantá-la via Intune e SCCM

A causa raiz foi a ausência de uma baseline segura consistente. A remediação adequada é definir uma baseline (gold image + políticas automatizadas) que obrigue EDR, patching automático, MFA e hardening CIS, e então implantá-la em escala por meio de ferramentas de gerenciamento corporativo (Intune para dispositivos em nuvem, SCCM para ambientes on-prem). Lembretes por e-mail (A) não garantem aplicação. Desativar a segurança (C) e a seleção por departamento (D) recriam as mesmas vulnerabilidades que causaram o incidente.

Questão 8: Alternativa A — Implementar uma gold image endurecida pelo CIS com EDR, MFA e patching automático, e implantá-la por meio de ferramentas de gerenciamento corporativo como SCCM ou Intune

A HIPAA exige salvaguardas (administrativas, físicas e técnicas) para a ePHI. A melhor salvaguarda técnica é uma gold image endurecida pelo CIS, que reúna EDR (proteção contra malware), MFA (controle de acesso) e patching automático (gestão de vulnerabilidades), implantada por ferramentas corporativas para que cada estação seja idêntica e auditável.

AV de consumidor (B), BYOD sem padrões (C) e pular o hardening (D) violam os requisitos de salvaguarda técnica da HIPAA.

Questão 9: Alternativa B — Importar as Microsoft Security Baselines como modelos ADMX, implantá-las via Group Policy e aplicá-las por meio do SCCM

A Microsoft publica Security Baselines (modelos ADMX/ADML, backups de GPO e configuration items do SCCM) ajustados por seus engenheiros. Importar esses modelos para o Group Policy e combiná-los com o SCCM oferece aplicação centralizada, automatizada e auditável da baseline. Copiar manualmente a partir de capturas de tela (A) é propenso a erros e não escala. Inventar baselines personalizadas (C) descarta a pesquisa da Microsoft. Assumir os padrões (D) é inseguro—as configurações padrão do Windows são permissivas por design.

Questão 10: Alternativa C — Usar ferramentas de gerenciamento de configuração como Ansible ou SCCM para detectar continuamente o drift e remediar automaticamente os endpoints para a baseline segura

O drift é exatamente o que as baselines seguras e o gerenciamento de configuração existem para combater. O Ansible (ou o Desired Configuration Management do SCCM) pode varrer continuamente em busca de drift e alertar ou reconvergir automaticamente os sistemas para a baseline aprovada. Ignorar o drift (A) deixa o ambiente sem hardening. Reinstalações semanais (B) são destrutivas e não escalam. Desativar o gerenciamento de configuração (D) é o oposto de uma baseline e recria o problema original.